

SKJ 3143 ISM (TUTORIAL WEEK 12 – ONLINE DIY) Annex A

Physical Controls.

Given the internal audit findings, complete the following by suggesting an appropriate controls.

NO	AUDIT FINDING	CONTROLS
1	Network and power cables are observed running through common office areas and ceiling spaces without protective conduits or restricted access. Cabling is not clearly labelled, and there is no documented cabling layout. As a result, cables may be accidentally disconnected, tampered with, or damaged, potentially causing outages or enabling unauthorised interception	This observation indicates a failure to implement Control A.7.12 Cabling Security.
2	Critical IT equipment such as network switches and backup devices were located near windows and water sources without adequate physical protection. Some workstations were positioned in publicly accessible areas, allowing screens to be viewed by visitors. There is no formal risk assessment guiding the placement of sensitive equipment.	This observation highlights deficiencies in Control A.7.8 Equipment Siting and Protection and Control A.7.5 Protecting Against Physical and Environmental Threats.
3	Weaknesses were observed in Access to the network equipment room relies solely on a mechanical key shared among multiple staff members. There is no access log to record entry or exit, and visitors are occasionally allowed to enter the floor without being escorted. Visitor badges are not always issued, making it difficult to distinguish authorised personnel from unauthorised individuals.	This observation demonstrates a failure to meet the requirements of Control A.7.2 Physical Entry.
4	During after-hours inspections, confidential documents containing personal and financial information were found on desks. Several workstations were left logged in, with screens displaying sensitive applications. Although a clear desk policy exists, staff awareness and enforcement are insufficient, and compliance monitoring is not performed.	This observation describes a non-compliance with Control A.7.7 Clear Desk and Clear Screen.
5	Decommissioned laptops, desktops, and network devices are stored in an unsecured storeroom prior to disposal. There is no evidence that storage media are securely wiped or destroyed before disposal or re-use. Asset disposal approvals and certificates of destruction are not retained, increasing the risk of data leakage from residual information.	This observation indicates a violation of Control A.7.14 Secure Disposal or Re-use of Equipment and Control A.7.10 Storage Media.
6	The Operations Centre shares the same floor with general office areas and external contractors. There is no clear demarcation between public, staff-only, and restricted zones. Signage indicating restricted access areas is inconsistent, and some perimeter doors remain unlocked during office hours, allowing unrestricted movement within the floor.	This observation indicates a failure to implement Control A.7.1 Physical Security Perimeters and Control A.7.2 Physical Entry.

7	CCTV coverage does not include the entrance to the network equipment room or the corridor leading to it. Existing cameras are not actively monitored, and footage retention periods are undefined. As a result, the organisation may not be able to detect or investigate physical security incidents effectively.	This observation highlights a non-compliance with Control A.7.4 Physical Security Monitoring.
8	Laptops and removable storage devices are frequently taken off-site for remote work without formal authorisation, tracking, or encryption verification. There is no asset register indicating which devices are approved for offpremises use, and staff have not been trained on securing assets during travel or remote work.	This observation demonstrates a violation of Control A.7.9 Security of Assets Off-Premises.
9	USB drives are used for data transfer without classification or encryption controls. Obsolete storage media are disposed of through general waste bins, with no evidence of secure wiping or destruction procedures. Media handling responsibilities are not clearly assigned.	This observation indicates a failure to meet the requirements of Control A.7.10 Storage Media and Control A.7.14 Secure Disposal or Re-use of Equipment.
10	Sensitive documents containing personal data were observed left unattended on desks after office hours. Several workstation screens remained unlocked, and filing cabinets containing confidential information were not consistently locked.	This observation describes a non-compliance with Control A.7.7 Clear Desk and Clear Screen.
11	The network equipment room lacks temperature and humidity monitoring. There is no UPS for critical servers, and fire detection systems have not been tested within the last 12 months. These gaps increase the risk of equipment damage and prolonged service outages.	This observation indicates a failure to implement Control A.7.5 Protecting Against Physical and Environmental Threats and Control A.7.11 Supporting Utilities.
12	Preventive maintenance schedules for servers, fire suppression systems, and environmental controls are informal and not documented. Maintenance activities performed by third-party vendors are not supervised, and access is granted without logging or escort requirements. Maintenance records are incomplete, making it difficult to verify that critical equipment is maintained in line with manufacturer recommendations.	This observation highlights non-compliance with Control A.7.13 Equipment Maintenance.
13	It was observed that staff working in restricted areas frequently allowed unauthorised colleagues and external vendors to enter without formal approval or supervision. Sensitive discussions related to system administration and customer data were conducted openly within shared secure areas, increasing the risk of information disclosure. Additionally, there is no documented guidance outlining acceptable behaviour and restrictions when working in secure zones.	This observation demonstrates a violation of Control A.7.6 Working in Secure Areas.

14	Data processing areas rely on a single power supply without redundancy. Although an uninterruptible power supply (UPS) is installed, it supports only selected servers and has not been tested in the past 12 months. Air conditioning units serving the server room are not monitored continuously, and temperature alarms are not configured to alert responsible personnel. These gaps increase the risk of service disruption and equipment damage during power or cooling failures.	This observation describes a significant failure in Control A.7.11 Supporting Utilities and Control A.7.5 Protecting Against Physical and Environmental Threats.
----	---	---